

AnTank 统一 C 端 SSO 登录方案

AnTank 作为唯一登录入口 — 西九全站 SSO 集成设计

项目	TP2 — WestK 新售票网站
文档版本	v1.0
本	
日期	2026-06-17
基于规范	Customer Portal API Spec v1.7.1 · Customer-SSO-Design.md v1.4
编写方	AnTank IT (feng.wang@antank.com)
目标读者	AnTank 开发团队 · WestK IT (Chris Kwan)
状态	草稿, 待双方确认
与前方案关系	本方案取代 antank-westk-oidc-design.md (Chain W / Chain T 双向 OIDC) 及 antank-westk-silent-sso-design.md (静默 SSO), 采用 AnTank 作为 唯一 登录入口的集中式架构

目录

- [1. 背景与目标](#)
- [2. 架构总览](#)
- [3. 用户分类](#)
- [4. AnTank 统一登录界面](#)
- [5. 认证流程](#)
 - [6. 5.1 存量西九 Email 用户 \(密码登录\) — 调用西九三步认证接口](#)
 - [7. 5.2 Email 验证码 \(OTP\) 登录 — 所有用户通用, AnTank 自行实现](#)
 - [8. 5.3 新 Email 用户 \(密码登录\)](#)

- 9. 5.4 [手机号用户](#)
- 10. 5.5 [第三方 OAuth 用户](#)
- 11. [西九各网站 SSO 集成 \(AnTank 作为 IdP\)](#)
- 12. [SSO 登出](#)
- 13. [新用户注册](#)
- 14. [接口调用安全规范](#)
- 15. [数据同步](#)
- 16. [实施检查清单](#)
- 17. [待确认事项](#)

1. 背景与目标

1.1 现状与痛点

前两套方案（[antank-westk-oidc-design.md](#) / [antank-westk-silent-sso-design.md](#)）均维持"双重登录入口"架构：西九 Customer Portal 保留自有登录页，与 AnTank 登录页并存，形成如下截图所示的两套界面：

西九 Customer Portal 原有登录界面（即将废弃）

westK
西九文化區

EN 繁 简

Log in to MyWestK Account

Log in to your MyWestK account to continue with membership purchase or manage your account and preferences.

Don't have an account yet? [Register an account](#)

Email*

Password*

☒ Remember me

* required field

[FORGOT PASSWORD?](#)

[Back](#)

[Log in](#)

此登录界面（[my.westk.hk](#) 上的 "Log in to MyWestK Account"）在本方案中取消。

双入口架构带来的主要问题：

问题	说明
用户体验割裂	用户在不同网站看到两套不同的登录 UI，品牌一致性差
账号体系分裂	存量 CRM 账号与新 AnTank 账号并存，认证逻辑复杂
注册路径不统一	西九 Customer Portal 有自己的注册流程，与 AnTank 重叠
维护成本高	双方各自维护登录、注册、忘记密码等功能

1.2 新方案核心思路

取消西九 Customer Portal 的 C 端登录界面，由 AnTank 提供唯一的 C 端 SSO 登录入口。

- AnTank 票务网站（westkticket.com）承担所有 C 端用户的登录、注册、忘记密码全流程
- 西九旗下所有网站（M+、HKPM、WestK、myWestK）的登录入口，统一跳转至 AnTank 登录页完成认证
- AnTank 按照 Customer Portal API Spec v1.7.1 实现一套完整的 OAuth 2.0 授权服务器接口，西九各网站作为 OAuth 客户端接入
- 对于存量西九 Email 用户，AnTank 在后台调用西九提供的三步认证接口完成鉴权，用户无感知
- 对于新用户（新 Email、手机号、第三方 OAuth），全部由 AnTank 内部处理

1.3 目标

1. 用户在任何西九系网站点击登录，均跳转至 AnTank 统一登录页
2. AnTank 完成认证后，通过 SSO 回调，各西九网站静默建立本地登录态
3. 存量约 1 万个西九 CRM Email 账号，登录体验不中断（AnTank 后台代理鉴权）
4. 新用户注册统一在 AnTank 完成，可选同步至西九 CRM
5. 符合企业级接口安全规范（见第 9 节）

2. 架构总览

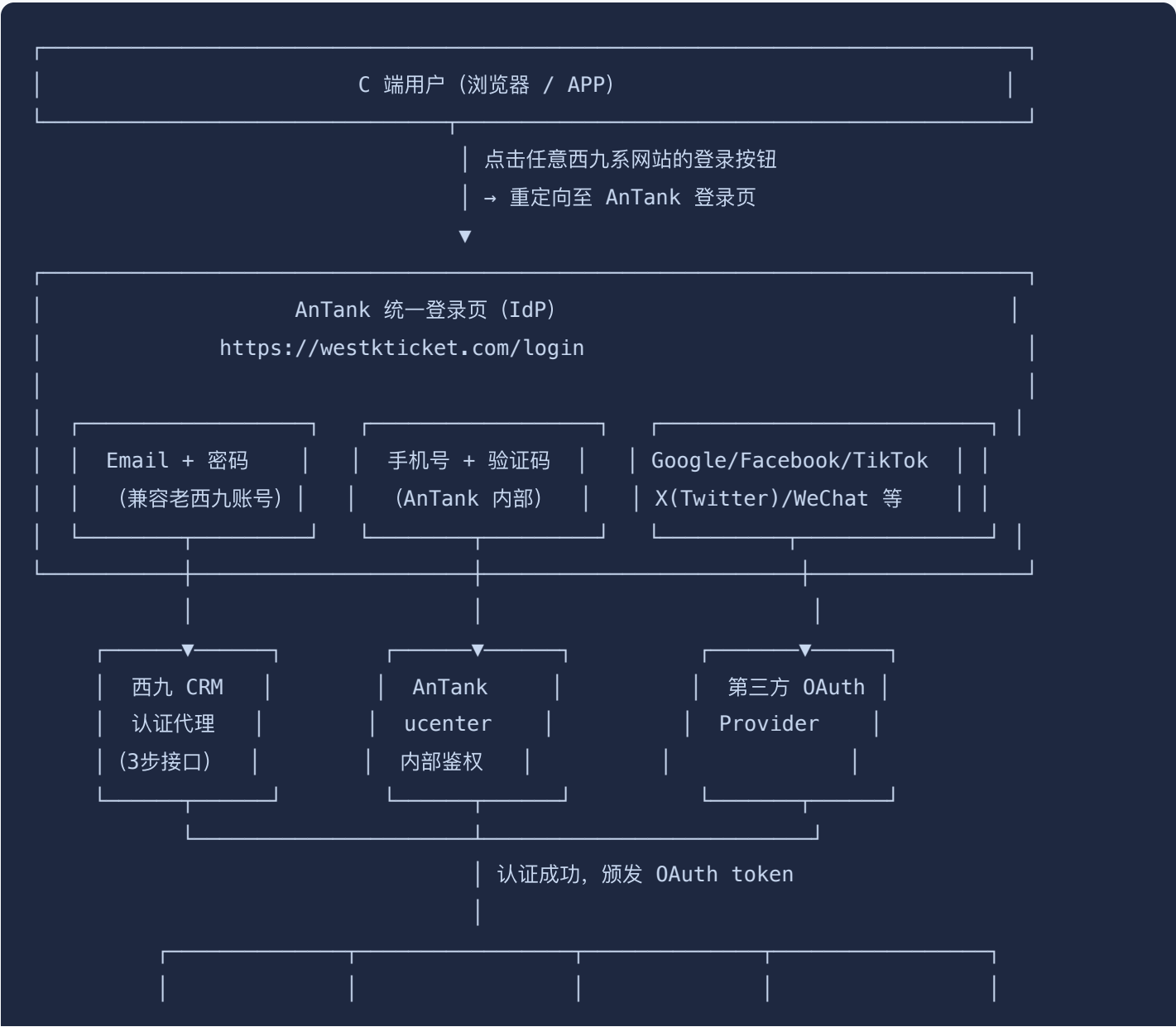
2.1 角色定义

角色	系统	域名	说明
IdP（身份提供商）	AnTank 票务平台	westkticket.com	唯一 C 端 SSO 登录入口，颁发 OAuth token
SP（服务提供商）	西九官网	www.westk.hk / my.westk.hk	OAuth 客户端，接受 AnTank token 建立登录态

角色	系统	域名	说明
SP	M+ 官网	www.mplus.org.hk	同上
SP	HKPM 官网	www.hkpm.org.hk	同上
SP (兼 IdP)	AnTank 票务平台	westkticket.com	同时也是 SP：用户在票务网站本身购票、登录，票务网站自身维护登录态
鉴权后端	西九 Customer Portal API	CustomerPortal-API-URL	仅供 AnTank 后端调用，验证存量 CRM Email 账号

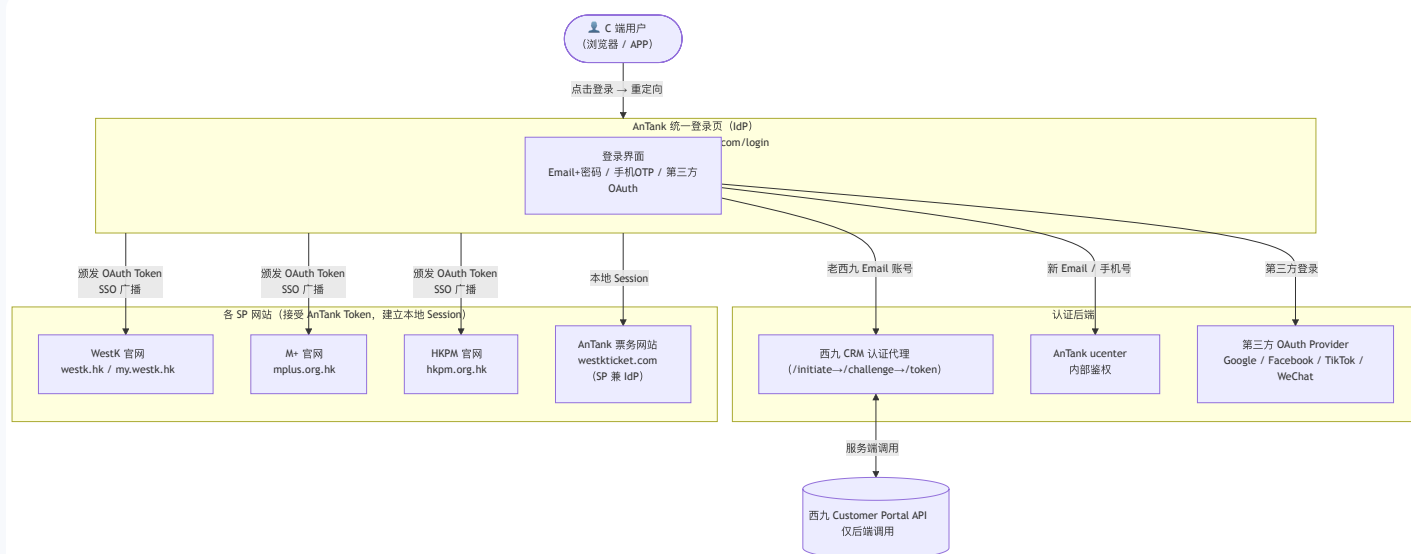
西九 Customer Portal API 不再直接面向 C 端用户；用户感知到的唯一登录入口是 AnTank。

2.2 整体架构图



WestK 官网 westk.hk (SP)	myWestK 官网 my.westk.hk (SP)	M+ 官网 mplus.org.hk (SP)	HKPM 官网 hkpm.org.hk (SP)	AnTank 票务网站 westkticket.com (SP 兼 IdP)
------------------------------	-----------------------------------	-------------------------------	--------------------------------	--

(各网站接收 token, 建立本地 Session, SSO 完成)



2.3 协议选型

层次	协议	说明
AnTank IdP 对外	OAuth 2.0 Authorization Code Flow (兼容 Customer Portal API Spec v1.7.1)	西九各网站最小改动接入
AnTank 内部 (存量用户)	西九三步认证 API (/initiate → /challenge → /token)	AnTank 后端对西九 API 的服务端调用, 不暴露给前端
安全签名	RS256 / ES256	JWT 签名 + 接口签名双重保护

3. 用户分类

类型	描述	认证方式	账号管理
A 类：存量西九 Email 会员	上线前已在西九 CRM 注册且持有会员卡	密码登录：AnTank 后台代理调西九三步接口；验证码登录：AnTank 自行发送 OTP	西九 CRM（密码鉴权）+ AnTank ucenter（建档/票务）
B 类：存量西九 Email 非会员	上线前已在西九 CRM 注册但无会员卡	同上	同上；首次登录成功后实时建档
C 类：新 Email 用户	上线后在 AnTank 以 Email 注册	AnTank 内部鉴权	AnTank ucenter
D 类：手机号用户	在 AnTank 以手机号 + 验证码注册/登录	AnTank 内部短信 OTP	AnTank ucenter
E 类：第三方 OAuth 用户	通过 Google / Facebook / TikTok / X / 微信等登录	第三方 OAuth 2.0	AnTank ucenter（open_member 绑定）

上线前数据迁移（上线节点：9/1）： A 类会员账号（邮箱、会员等级、有效期、当前优惠）上线前批量导入 `westk_legacy_accounts` 迁移表；**密码不迁移**。B 类（无会员卡的存量邮箱用户）不单独迁移，但上线前同样收录进迁移表，首次登录成功后实时建档。迁移表同时作为存量账号识别标志——见 §3.2 迁移表设计。

3.2 迁移表设计（`westk_legacy_accounts`）

上线前（9/1 前）从西九 CRM 批量导入，双重用途：

- 1. **身份识别：** Email 登录时，查此表判断是否为西九存量账号
- 2. **建档预填：** 首次登录成功后，从此表读取会员数据填充 AnTank 档案

```
CREATE TABLE westk_legacy_accounts (  
  id          BIGINT          NOT NULL AUTO_INCREMENT PRIMARY KEY,  
  email       VARCHAR(255)    NOT NULL UNIQUE,          -- 唯一识别标识，不存密码  
  membership_tier VARCHAR(100) NULL,                    -- 会员等级（如 M+ Pioneers）  
  membership_expiry DATE      NULL,                    -- 会员有效期  
  current_offers JSON         NULL,                    -- 当前优惠 / 优惠券  
  antank_member_id BIGINT     NULL,                    -- 首次登录后关联 AnTank member.id  
  first_login_at DATETIME     NULL,                    -- NULL = 尚未登录过  
  migrated_at  DATETIME     NOT NULL                    -- 迁移入库时间  
);
```

判断逻辑：Email 存在于此表 → 西九存量账号（A/B 类）。无需单独维护"是密码用户还是验证码用户"的标记——两条登录路径均向存量用户开放，由用户自行选择。

4. AnTank 统一登录界面

AnTank 现有登录界面即为本方案的唯一 C 端 SSO 登录入口，支持所有用户类型：

AnTank 统一登录界面（当前设计）

Log in

Welcome back. Sign in to continue.

Email

Log in with phone

Mplus01

.....



Dynamic Code

3987

Forgot password?

Log in

Continue as guest

Log in with verification code

Or continue with



By continuing, you agree to our [Terms of Service](#) and [Privacy Policy](#)

Don't have an account? [Sign up](#)

界面特征：WestK 品牌 LOGO + 多语言切换（EN）、Email/手机号双模式、图形验证码、忘记密码、社交登录（Google、Facebook、TikTok、X、微信）、游客模式、注册入口。

4.1 登录方式矩阵

登录方式	适用用户	后端处理逻辑
Email + 密码	A/B 类（存量西九账号） + C 类（新账号）	查 <code>westk_legacy_accounts</code> 迁移表：命中 → 调西九三步接口（password 路径）；未命中 → AnTank 本地验密
Email + OTP 验证码	所有 Email 用户	AnTank 自行向该邮箱发送验证码，AnTank 内部验证， 不调用西九接口
手机号 + 验证码	D 类	AnTank 内部短信 OTP
Google / Facebook / TikTok / X / 微信	E 类	AnTank 标准第三方 OAuth
游客登录	无账号访客	生成临时 session，不建账号

4.2 界面个性化（根据来源 SP 展示）

各西九网站跳转至 AnTank 登录页时，可携带 `source` 参数（对应 Customer Portal API Spec Appendix A Channel Names），AnTank 登录页根据来源展示对应品牌信息（M+ / HKPM / WestK 等）。

```
GET https://westkticket.com/oauth2/authorize
?client_id={SP Client ID}
&source=Online%20MyWestkowloon%20%E2%80%93%20WKDA ← Channel Name
&redirect_uri={SP Callback URL}
&response_type=code
&lang=zh
```

5. 认证流程

5.1 存量西九 Email 用户（密码登录） — 调用西九三步认证接口

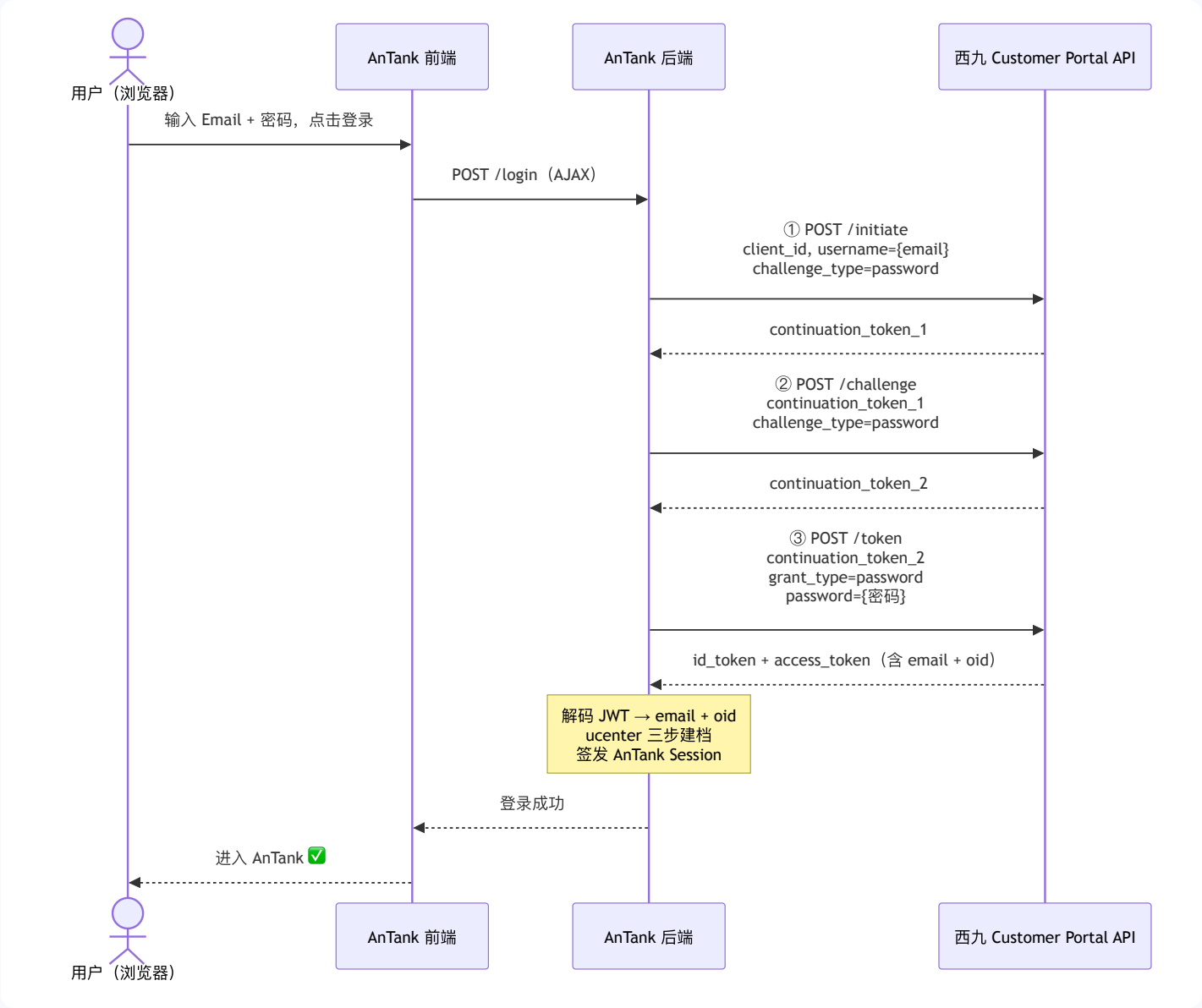
当用户选择“邮箱 + 密码”登录时，AnTank 后端查询 `westk_legacy_accounts` 迁移表（见 §3.2）：命中则判定为存量西九账号，调用西九 Customer Portal 三步认证接口完成密码验证。**此调用为纯后端服务端调用，用户不感知跳转。** 邮件验证码（OTP）登录由 AnTank 统一实现，见 §5.2，不调用西九接口。

接口说明 (password 路径)

步骤	接口	请求参数	返回
① 发起认证	POST /initiate	client_id , username (Email) , challenge_type=password	continuation_token
② 选择挑战	POST /challenge	client_id , continuation_token , challenge_type=password	新 continuation_token
③ 提交密码 换 Token	POST /token	client_id , continuation_token , scope , grant_type=password , password=<密码>	id_token / access_token

密码登录时序 (A/B 类用户, grant_type=password)





待确认：密码留存策略（见 §12 #5）— A/B 类用户通过西九接口密码验证成功后，是否在 AnTank 侧留存密码哈希？若留存，后续密码登录可直接在 AnTank 本地验证，不再每次依赖西九接口；若不留存，每次密码登录均需调西九接口。需双方产品确认。

邮件验证码（OTP）登录见 §5.2，由 AnTank 统一实现，**不调用西九接口**。

ucenter 三步建档流程（密码路径）

西九 /token 接口返回 id_token → 解码得 email + oid (D365 Object ID)

```
Step 1: 按 openid 查 openmember (已绑定, 最快路径) |
WHERE openid='{oid}' AND appkey='WestKPortal' AND company_id=53440 |
✅ 找到 → 取 memberid → 更新 westk_legacy_accounts.first_login_at |
→ 签发 AnTank Session → 完成 |
```

↓ 未找到

```
Step 2: 按 email 查 member (首次密码登录的存量西九用户) |
WHERE email='{email}' AND company_id=53440 |
✅ 找到 → 创建 openmember (openid=oid) 绑定记录 |
→ 从 westk_legacy_accounts 预填会员数据 |
→ 更新 first_login_at → 签发 AnTank Session → 完成 |
```

↓ 未找到

```
Step 3: 存量西九用户, AnTank 无档案 (首次登录) |
→ 自动创建 member (email 建档) + openmember (openid=oid) |
→ 从 westk_legacy_accounts 读取 membership_tier / expiry / offers |
→ open_source = 'westk' |
→ 更新 westk_legacy_accounts.antank_member_id + first_login_at |
→ 签发 AnTank Session → 完成 |
```

5.2 Email 验证码 (OTP) 登录 — 所有用户通用, AnTank 自行实现

所有 Email 用户 (A/B/C 类) 均可使用邮件验证码登录, 全程由 AnTank 自行发送和验证 OTP, 不调用西九接口。

用户输入 Email → 点击"发送验证码"

→ AnTank 后端生成 OTP, 通过 AnTank 邮件系统发送至该 Email

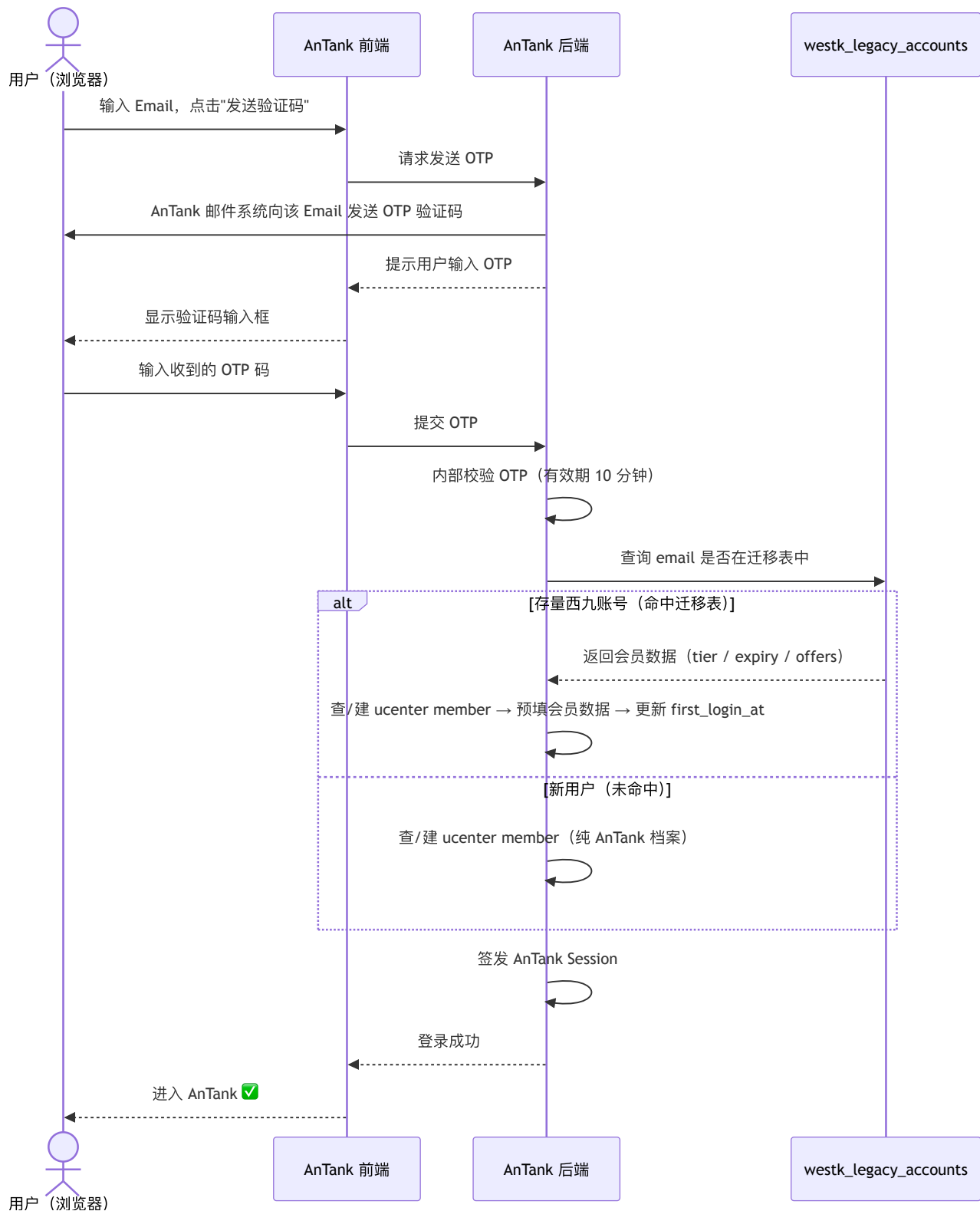
→ 用户输入收到的 OTP 码

→ AnTank 内部验证 OTP (有效期 10 分钟)

→ 查 westk_legacy_accounts (email 是否命中)

└─ 命中 → 存量西九账号 → 按 email 查/建 ucenter member → 预填会员数据 → 更新 first_login_at

└─ 未命中 → 新用户 (C 类) → 查/建 ucenter member (纯 AnTank 档案)
→ 签发 AnTank Session → 完成



5.3 新 Email 用户 (密码登录)

C 类用户在 AnTank 注册, AnTank 内部维护 Email + 密码, 鉴权流程完全在 AnTank ucenter 内完成。

用户输入 Email + 密码

- AnTank 后端查 westk_legacy_accounts (未命中 → 确认为新 AnTank 用户)
- 查 ucenter member 表 (email + company_id=53440)
- 找到 → 本地验密 → 签发 AnTank Session → 完成

5.4 手机号用户

D 类用户，AnTank 内部完成短信 OTP 鉴权：

用户输入手机号 → AnTank 发送 SMS OTP

- 用户提交 OTP → AnTank 验证
- ucenter 查 member (mobile) → 找到/新建 → 签发 Session → 完成

5.5 第三方 OAuth 用户

E 类用户，走标准 OAuth 2.0 授权码流程 (Google / Facebook / TikTok / X / 微信)：

用户点击第三方图标 → 跳转第三方授权页 → 授权成功回调 AnTank

- AnTank 从第三方获取 access_token + 用户信息 (email / openid)
- ucenter 查 openmember (openid + appkey) → 找到/新建 → 签发 Session → 完成

6. 西九各网站 SSO 集成 (AnTank 作为 IdP)

AnTank 实现与 **Customer Portal API Spec v1.7.1** 兼容的 OAuth 2.0 服务端接口，使西九各网站现有集成代码改动最小（仅更换 endpoint 地址和 client 凭据）。

6.1 AnTank OAuth 接口总览

接口	方法	AnTank 端点	对应 API Spec 章节
Checking API	GET	/s/checking	§1.2
授权端点	GET	/services/oauth2/authorize	§1.3
Token 端点	POST	/services/oauth2/token	§1.6
SSO 通知	GET	/s/sso-notify (回调各 SP)	§1.7
单点登出	GET	/SingleSignOut	§1.8

接口	方法	AnTank 端点	对应 API Spec 章节
注册端点	GET	/s/register	§1.9
Session 同步	POST	/s/user-session-sync	§1.10

6.2 SSO 完整流程（以西九官网 westk.hk 为例）



```
{redirect_uri}?code={AuthCode}
&is_authorization_code=true
```

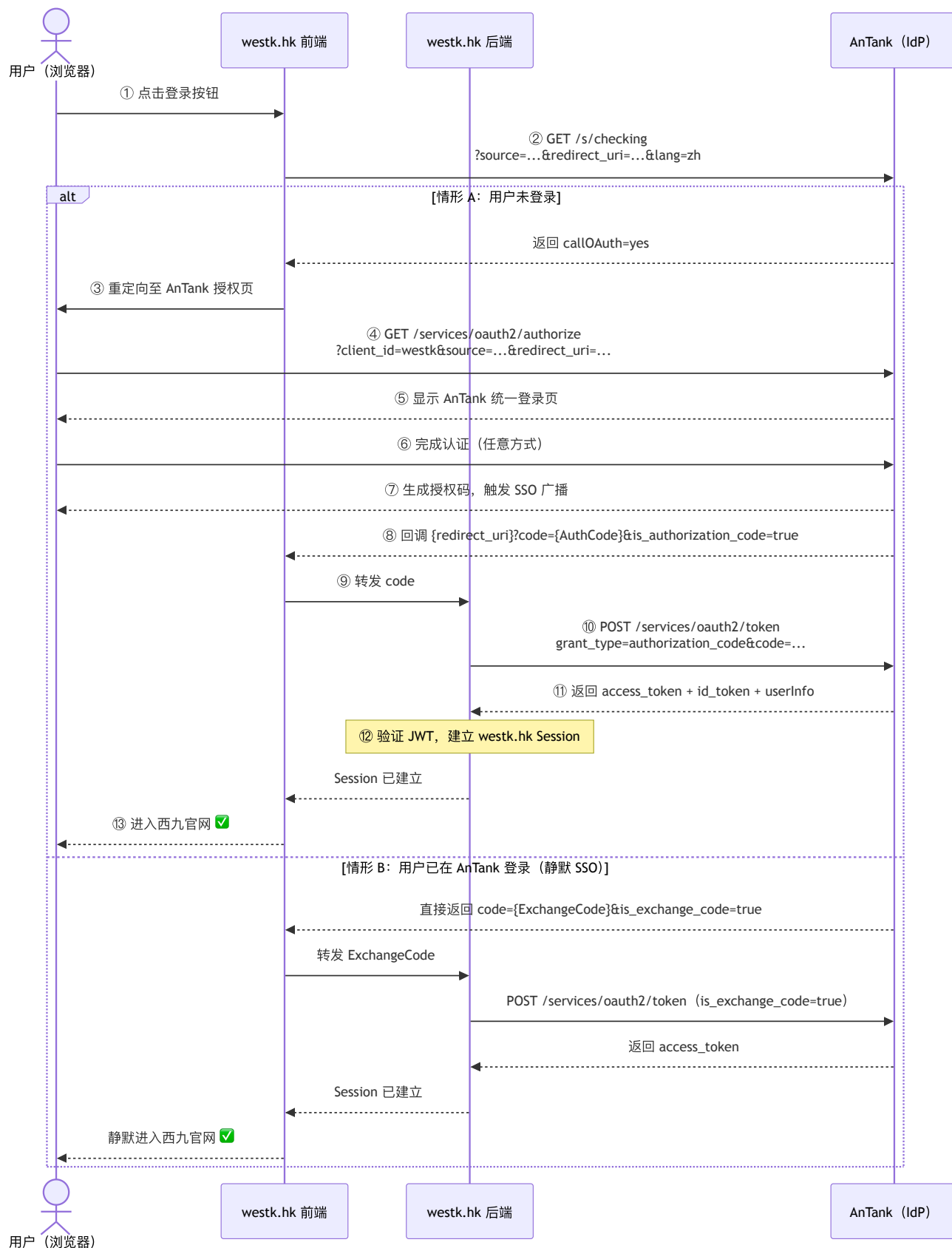
⑨ 转发 code 至后端

⑩ POST /services/oauth2/token
grant_type=authorization_code
code={AuthCode}
is_exchange_code=false
client_id/secret
source=...

⑪ 返回 access_token (JWT)
+ id_token + userInfo

⑫ 解码 JWT, 验证身份
建立 westk.hk Session

⑬ 用户进入西九官网 



情形 B (用户已在 AnTank 登录): Checking API 直接返回 `code={ExchangeCode}&is_exchange_code=true` , westk.hk 后端用 ExchangeCode 换取 access_token, 无需用户再次输入凭据, 实现静默 SSO。

6.3 多网站 SSO 同步（登录广播）（是否需要这个功能？待讨论）

用户在 AnTank 完成认证后，AnTank 向所有注册了 SSO 回调地址的西九系网站推送 Exchange Code，使各站静默建立登录态：

AnTank 认证完成

- |
- └─ 调用 westk.hk 的 checkAuth API (SSO 回调) → 返回 ExchangeCode
- └─ 调用 mplus.org.hk 的 checkAuth API → 返回 ExchangeCode
- └─ 调用 hkpm.org.hk 的 checkAuth API → 返回 ExchangeCode

各网站收到 ExchangeCode → 调用 AnTank /services/oauth2/token 换取 access_token
→ 各自建立本地 Session
→ 用户在所有西九系网站均处于登录态

6.4 AnTank Token 响应格式

与 Customer Portal API Spec v1.7.1 §1.6 保持兼容：

```
{
  "access_token": "{JWT, 含 email + antank_id + oid}",
  "scope": "web openid",
  "id_token": "{RS256 签名 JWT}",
  "token_type": "Bearer",
  "issued_at": "1753425160000",
  "expires_in": "1753425163600",
  "userInfo": {
    "MembershipStatus": "Active | Inactive | null",
    "MembershipTierName": "M+ Pioneers | null",
    "Success": true,
    "customer": {
      "email": "user@example.com",
      "antank_id": 54321,
      "westk_oid": "{D365 Object ID (如有)}"
    }
  }
}
```

JWT 解码可得的关键字段：

字段	说明
<code>email</code>	用户邮箱
<code>antank_id</code>	AnTank ucenter member ID
<code>westk_oid</code>	西九 D365 Object ID（存量用户有，新用户为 null）
<code>login_type</code>	<code>email</code> / <code>phone</code> / <code>google</code> / <code>wechat</code> 等
<code>company_id</code>	固定 <code>53440</code> （西九租户）

6.5 各网站接入配置

每个 SP（西九系网站）需向 AnTank 注册以下信息：

配置项	说明	示例
<code>client_id</code>	AnTank 分配的 Client 标识	<code>westk-official</code> / <code>mplus-official</code> / <code>hkpm-official</code>
<code>client_secret</code>	AnTank 生成，安全渠道传递	{256-bit 随机串}
<code>redirect_uris</code>	SP 回调 URL 白名单（精确匹配）	<code>https://my.westk.hk/auth/callback</code>
<code>source</code>	Channel Name（见 API Spec Appendix A）	<code>Online MyWestkowlon - WKDA</code>
<code>checkAuth_url</code>	AnTank SSO 广播时回调该网站的地址	<code>https://www.api.westkowlon.hk/ciam/oauth/check</code>

7. SSO 登出（是否需要这个功能？待讨论）

用户在任一西九系网站点击登出，触发全局登出（与 Customer Portal API Spec §1.8 兼容）：

```

用户在 westk.hk 点击登出
|
└─> westk.hk 调用 AnTank 登出接口：
      GET https://westkticket.com/SingleSignOut
          ?source=Online%20MyWestkowlon%20%E2%80%93%20WKDA
          &redirect_uri={westk 登出后跳转页}
      |
      AnTank 吊销该用户 Session
  
```

```
|
|→ 回调 westk.hk checkAuth API → 通知清除 Session
|→ 回调 mplus.org.hk checkAuth API → 通知清除 Session
|→ 回调 hkpm.org.hk checkAuth API → 通知清除 Session
|
→ 所有网站用户均已登出, 重定向至 redirect_uri
```

8. 新用户注册

注册完全由 AnTank 承担, 与 Customer Portal API Spec §1.9 兼容:

```
GET https://westkticket.com/s/register
?client_id={SP Client ID}
&source={Channel Name}
&redirect_uri={SP 注册后回调 URL}
&lang=zh
```

8.1 注册流程

1. 用户在 AnTank 注册页完成信息填写 (Email 或手机号)
2. AnTank 完成邮箱验证 / 手机验证码验证
3. AnTank ucenter 建立 member 账号
4. 注册成功 → 生成 ExchangeCode → 回调 SP:
{redirect_uri}?code={ExchangeCode}&is_exchange_code=true
5. SP 用 ExchangeCode 换取 access_token → 建立登录态

8.2 注册时的条款与数据同步选项

条款	必选/可选	说明
条款 a	必选	同意注册为 AnTank 票务网站用户
条款 b	可选	同意同时注册为西九会员, 授权将个人信息同步至西九 CRM (需不需"同时注册为西九会员"要待定, 没有登录界面了, 大概率不需要了)

勾选条款 b → AnTank 后端异步调用西九 CRM 接口写入新用户信息 (不阻塞注册主流程)。

9. 接口调用安全规范

适用于 AnTank 与西九 Customer Portal API 之间的所有后端服务端接口调用。

9.1 传输安全

- 强制 HTTPS (TLS 1.2+); HTTP 请求一律拒绝 (400) 或 301 重定向至 HTTPS

9.2 身份认证

- 采用 OAuth 2.0 Client Credentials 模式 + JWT Token
- 每对调用关系持有独立的 `client_id` / `client_secret` , 确认调用方身份
- JWT Token 有效期 ≤ 1 小时, 过期后重新申请

9.3 请求签名 (防篡改)

- 请求体 (Body) + `X-Timestamp` (Unix 时间戳, 精确到秒) + `X-Nonce` (随机字符串) 拼接后做非对称签名
- 算法: RS256 (RSA 2048-bit 起) 或 ES256
- 签名置于请求头: `X-Signature: {Base64URL 编码的签名值}`
- 接收方验签, 签名不匹配直接拒绝 (HTTP 400)

```
待签名字符串 = SHA256(request_body) + "." + timestamp + "." + nonce  
签名 = RSA_SIGN(待签名字符串, 私钥)
```

9.4 防重放攻击

- 请求头携带 `X-Timestamp` (精确到秒) 和 `X-Nonce` (16 字节随机串)
- 接收方校验: $|\text{now} - \text{timestamp}| \leq 300\text{s}$ (5 分钟时间窗口)
- `nonce` 在时间窗口内去重 (Redis TTL 缓存, key= `nonce:{nonce}` , TTL=300s)
- 超出时间窗口或 `nonce` 重复 $\rightarrow$ 拒绝请求 (HTTP 400, 错误码 `replay_detected`)

9.5 敏感字段加密 (PII 保护)

- 手机号、邮箱等 PII 字段, 在 TLS 层之外, 额外做 AES-256-GCM 字段级加密
- 加密密钥通过 KMS (Key Management Service) 管理, 禁止硬编码
- 加密格式: `ENC:{Base64URL(IV + Ciphertext + AuthTag)}`

9.6 审计与脱敏

- 所有跨系统调用记录**完整审计日志**（请求时间、接口名、调用方、响应码、耗时）
- 日志中 PII 数据**脱敏处理**：
- 手机号： `+852****3456` （保留前 4 位国家码 + 后 4 位）
- 邮箱： `u***@example.com`
- 密码 / OTP： **完全不记录**

9.7 失败处理

- 同步失败支持**自动重试**（指数退避：1s → 2s → 4s，最多 3 次）
- 所有写入操作设计为**幂等**（以业务唯一键去重，重复调用不产生重复数据）
- 超过重试次数的失败请求进入**死信队列（DLQ）**，告警并由运营人工处理

10. 数据同步（需不需要"同时注册为西九会员"要待定，没有登录界面了，大概率不需要了）

CRM 对接说明： 西九 CRM 深度对接（会员数据双向同步、D365 字段映射等）另行召开专项会议讨论，不纳入本 SSO 登录流程范畴。本节 §10.1 仅描述注册触发的单向推送接口，其余 CRM 集成待 CRM 专项文档明确后更新。

10.1 会员数据同步（AnTank → 西九 CRM）

触发场景	同步接口	调用方式
新用户注册（勾选条款 b）	西九 WK-USER-01（新用户接收接口）	AnTank 后端异步
用户购买 / 续费会员卡	西九 WK-MEMBER-01（会员变更通知接口）	AnTank 后端异步

10.2 订单查询

西九官网需展示用户票务订单时，调用 AnTank 提供的订单查询接口：

- **接口：** AT-ORDER-01（AnTank 提供，供西九后端查询）
- 支持按 BU / 演出类型过滤，剔除"租场"类非西九项目

10.3 Session 同步

各网站可按需调用 AnTank 的 Session 同步接口（对应 API Spec §1.10），延长用户活跃时间：

```
POST https://westkticket.com/s/user-session-sync
{
```

```
"access_token": "...",
"client_id": "...",
"client_secret": "...",
"source": "..."
}
```

建议各网站最多每 12 小时调用一次，避免对 AnTank 产生不必要压力。

11. 实施检查清单

11.1 AnTank 侧（主要工作方）

OAuth 服务端接口实现

- [] 实现 `GET /s/checking`
— Checking API（检查当前 SSO 状态，返回 ExchangeCode 或 callOAuth=yes）
- [] 实现 `GET /services/oauth2/authorize` — 授权端点（参数验证、redirect_uri 白名单、展示统一登录页、生成一次性 code）
- [] 实现 `POST /services/oauth2/token` — Token 端点（授权码/ExchangeCode 换 JWT access_token + id_token）
- [] 实现 `GET /SingleSignOut` — 全局单点登出 + SSO 广播吊销
- [] 实现 `GET /s/register` — 注册端点（展示 AnTank 注册页，注册完成后回调 SP）
- [] 实现 `POST /s/user-session-sync` — Session 活跃度同步
- [] 实现 SSO 广播机制（登录成功后主动回调各网站 checkAuth URL，分发 ExchangeCode）

西九三步认证代理（password 路径）

- [] 接入西九 `/initiate` 接口（Email + challenge_type=password → continuation_token）
- [] 接入西九 `/challenge` 接口（challenge_type=password）
- [] 接入西九 `/token` 接口（grant_type=password 换 id_token/access_token）
- [] 实现存量账号探测逻辑：密码登录时，查 `westk_legacy_accounts` 迁移表，命中则调西九三步接口
- [] 实现 ucenter 三步建档（§5.1，含写回 `westk_legacy_accounts.antank_member_id + first_login_at`）

Email OTP 登录（AnTank 自行实现）

- [] 实现 AnTank 邮件 OTP 发送（有效期 10 分钟，防刷限速）
- [] 实现 OTP 内部校验逻辑

- [] OTP 验证通过后查 `westk_legacy_accounts` , 命中则预填会员数据建档

登录界面扩展

- [] 登录页支持 `source` 参数, 根据来源 SP 展示对应品牌
- [] 登录页支持 `lang` 参数 (en/tc/sc)
- [] Email 登录支持切换: 密码登录 ↔ OTP 邮件验证码登录

安全与配置

- [] 为每个西九系 SP 注册 `client_id` / `client_secret` , 配置 `redirect_uri` 白名单和 `checkAuth_url`
- [] 实现请求签名 (RS256) + 验签中间件
- [] 实现 nonce 去重 (Redis)
- [] 实现 PII 字段 AES-256-GCM 加密 + KMS 密钥管理
- [] 实现审计日志 (含 PII 脱敏)
- [] 实现失败重试 + 死信队列

数据迁移

- [] 上线前 (9/1 前) 从西九 CRM 批量导入存量账号至 `westk_legacy_accounts` (email、membership_tier、membership_expiry、current_offers)
- [] 验证迁移表数据完整性 (email 唯一性、会员等级字段)
- [] 建立迁移表索引: `email` (UNIQUE)、`antank_member_id`

11.2 西九 WestK 侧

Customer Portal API (后端接口)

- [] 开放 `/initiate` 接口供 AnTank 后端调用 (含接口文档、认证方式、测试环境 URL)
- [] 开放 `/challenge` 接口
- [] 开放 `/token` 接口 (grant_type=password; oob 路径 AnTank 已自行实现, 西九侧无需开放)
- [] 提供测试 / UAT / PROD 各环境的接口 URL 和 client_id

各网站 SSO 接入

- [] westk.hk / my.westk.hk: 将登录按钮链接改为调用 AnTank Checking API → 跳转 AnTank 授权页
- [] mplus.org.hk: 同上
- [] hkpm.org.hk: 同上
- [] 各网站实现 Token 兑换逻辑 (收到授权码 → 调 AnTank `/services/oauth2/token` → 建本地 Session)
- [] 各网站实现 checkAuth 回调 URL, 供 AnTank SSO 广播时调用
- [] 各网站实现 Session 登出接收逻辑

配置提供

- [] 提供各网站各环境的 `redirect_uri` 列表（供 AnTank 注册白名单）
- [] 提供各网站的 `checkAuth_url`（供 AnTank SSO 广播注册）
- [] 确认各网站使用的 `source` Channel Name（见 API Spec Appendix A）

12. 待确认事项

#	优先级	问题	目标方
1	 HIGH	西九三步认证接口详细规范： <code>/initiate</code> 、 <code>/challenge</code> 、 <code>/token</code> 的完整接口文档（参数格式、认证方式、错误码、速率限制）需西九提供	Chris Kwan
2	 HIGH	西九三步接口的认证方式：AnTank 后端调用时，如何证明调用方身份？使用 <code>client_id/secret</code> 还是 mutual TLS？	Chris Kwan
3	 HIGH	测试环境接口 URL： <code>/initiate</code> 、 <code>/challenge</code> 、 <code>/token</code> 的 DEV / UAT 地址	Chris Kwan
4	 HIGH	各西九系网站 <code>checkAuth</code> URL： <code>westk.hk</code> 、 <code>mplus.org.hk</code> 、 <code>hkpm.org.hk</code> 的 SSO 广播回调地址（各环境）	Chris Kwan
5	 HIGH	密码留存策略（待确认）：A/B 类用户通过西九三步接口密码验证成功后，AnTank 侧是否留存密码哈希？若留存 → 后续可本地验密，降低对西九接口依赖；若不留存 → 每次密码登录均调西九接口，强依赖西九接口稳定性。建议优先确认。	AnTank 产品 + Chris Kwan
6	 MID	无邮箱的手机/第三方用户如何在西九 CRM 建档： <code>userInfo</code> 中若无 email，西九 CRM 建档策略（占位邮箱 or 跳过 or 引导补填）	Chris Kwan + AnTank 产品
7	 MID	西九 CRM 是否需要新增 <code>antank_id</code> 字段：用于存储 AnTank member ID，支持跨系统账号关联	Chris Kwan
8	 MID	西九三步接口的速率限制：并发登录峰值时（如演出开票），接口是否有 QPS 限制？是否需要 AnTank 侧做本地缓存	Chris Kwan
9	 MID	<code>ExchangeCode</code> / <code>AuthCode</code> 有效期：AnTank 生成的授权码建议 15 分钟，与 Customer Portal API Spec 保持一致，需各 SP 确认	各 SP 开发团队
10	 LOW	各网站 <code>source</code> Channel Name 确认：M+、HKPM 各自使用的 <code>source</code> 值（见 Appendix A）需与各网站团队确认	Chris Kwan + 各网站负责人

#	优先级	问题	目标方
11	● LOW	APP WebView 场景：西九 APP 内嵌 AnTank H5 时，登录态传递方式（URL 参数 vs postMessage）需双方技术团队确认	AnTank 移动端 + 西九 APP 团队

附录 A：废弃的方案说明

废弃方案	文件	废弃原因
Chain W / Chain T 双向 OIDC	antank-westk-oidc-design.md	双入口架构，用户体验割裂；本方案取消西九登录界面，统一至 AnTank
静默 SSO（自定义接口）	antank-westk-silent-sso-design.md	双方各建接口，维护成本高；本方案西九侧只需开放三步认证接口

附录 B：各环境 AnTank OAuth 端点

环境	基础地址
DEV	https://anticket.lengliwh.com
UAT	https://wkonline.ut.antank.cn
PROD HK	https://westkticket.com （或 wkonline.antankhk.com ）
PROD SZ	https://wksz.antankhk.com

附录 C：数据库影响

新增表

表	说明
westk_legacy_accounts	上线前从西九 CRM 批量导入，见 §3.2；兼作存量账号识别标志和会员数据预填来源

ucenter 现有表变更

表	变更内容
company_app	为每个西九系 SP (westk / mplus / hkpm) 新增记录, 存储 client_id/secret/redirect_uri/checkAuth_url
openmember	存储西九 D365 oid (open_source='westk'), 首次西九 Email 密码登录时写入
member	email 字段已存在; 新增 westk_sync (boolean) 标记是否已同步至西九 CRM

文档版本: v1.0 | 日期: 2026-06-16 | AnTank IT Team